

1/29

□

File No: EXP202313042

RESOLUTION OF TERMINATION OF THE PROCEDURE BY VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On December 22, 2023, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against HISPAPOST, S.A. (hereinafter, the defendant), through the Agreement that is transcribed:

<<

File No: EXP202313042

AGREEMENT TO INITIATE SANCTIONING PROCEEDINGS

From the actions taken by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: On September 28, 2022, the Spanish Agency for Data Protection received Report No. NI ***REPORT.1 from the LOCAL POLICE OF THE CITY COUNCIL OF LA PALMA (hereinafter, the LOCAL POLICE).

The LOCAL POLICE provided a report dated September 22, 2022, prepared by agents of the Local Police, which revealed the discovery of abandoned correspondence containing personal data, totaling 1,404 letters, bearing the logo of the company HISPAPOST S.A. (hereinafter HISPAPOST), which was contacted by the agents, acknowledging that the found correspondence should have been delivered by employees of CORREO INTELIGENTE POSTAL SL (hereinafter CI POSTAL), without understanding the reason why such delivery was not carried out and the correspondence was abandoned.

The letters belonged to various sending companies, including La Caixa, BBVA, Energía XXI, and Endesa.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/29

On September 13, 2022, a representative of the company CI POSTAL (Ms. A.A.A.) visited the LOCAL POLICE premises, and when shown the found letters, she recognized her company's logo, stating in her declaration that she was unaware of the reason why the correspondence had not been delivered; the letters belonged to the months between February and May 2022. This person stated that this correspondence should have been delivered among four workers, two of whom were no longer employed and two who were still working and had delivered their respective portions, and that since it was ordinary correspondence, it is impossible to ascertain which of the four delivery workers failed to perform their duties.

On September 22, 2022, this same representative of CI POSTAL returned to the police premises after being summoned again by the police; during this act, she was handed the correspondence, a total of 1,404 letters from the sending companies with the following distribution: La Caixa (596 letters), BBVA (57 letters), Naturgy (33 letters), Energía XXI (295 letters), Imagin (59 letters), Endesa (307 letters), MasMovil (1 letter), Telefax (3 letters), Totem (3 letters), Laboral Kutxa (1 letter), PSA (1 letter), Yoigo (1 letter), Orange (6 letters), Pra Group (1 letter), Jazztel (2 letters).

Record of HISPAPOST September 13, 2022

AFFECTED COMPANY

FOUND LETTERS

LA CAIXA

596

BBVA

57
 NATURGY
 33
 ENERGÍA XXI
 295
 IMAGIN
 59
 ENDESA
 307
 MASMOVIL
 1
 TELEFAX
 3
 LABORAL KUTXA
 1
 PSA FINANCIAL
 1
 YOIGO
 1
 ORANGE
 6
 PRA GROUP
 1
 JAZZTEL
 2

On November 17, 2022, a new complaint was received by the Spanish Agency for Data Protection from the Government Delegation in the Balearic Islands, which forwarded a document sent by the Superior Police Headquarters of the Balearic Islands regarding the location of a total of 5,354 abandoned letters in two different locations in La Palma, for which the company HISPAPOST was responsible, managing the delivery through its distributor in La Palma, CI POSTAL.

This is a total count of 5,354 letters with the following distribution of affected companies and located letters:

Notified to HISPAPOST on October 19, 2022

COMPANY	LETTERS
ENERGY XXI	1,420
LEXER	1
ENDESA	1,485
EQUIFAX	42
NATURGY	170
TELEFAX	4
GAES	1,470
PSA FINANC.	5

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/29
VODAFONE
16
INVEST CAPITAL
4
JAZZTEL
51
TR3A
8
YOIGO
5
ZOLVA
29
ORANGE
21
AYTO MADRID (TAX AGENCY)
1
MASMOVIL
17
AYTO SEVILLA (TAX AGENCY)
5
BANCO SABADELL
240
MC ABOGADOS
3
CAIXABANK
40
ASISA
2
BBVA
197

In relation to this incident, the following security breaches were reported to this Agency by various data controllers affected by the postal abandonments:

1. The controller BANCO SABADELL SA reported the breach on ***DATE.1.
2. The controller PSA FINANCIAL SERVICES reported the breach on ***DATE.5 and November 16, 2022.
3. The controller ASNEF-EQUIFAX INFORMATION SERVICES reported the breach on ***DATE.5 and November 15, 2022.
4. The controller INTRUM SERVICING SPAIN reported the breach on October 24, 2022, and November 21, 2022.
5. The controller VODAFONE ESPAÑA reported the breach on October 27, 2022, and November 25, 2022.
6. The controller PRA IBERIA SL reported the breach on November 1, 2022.
7. The controller CABOT FINANCIAL SPAIN SA reported the breach on November 3, 2022, and December 1, 2022.
8. The controller INVESTCAPITAL LTD reported the breach on November 18, 2022.
9. The controller EOS SPAIN SL reported the breach on November 17, 2022, and December 7, 2022.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of

Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), this complaint was forwarded to CI POSTAL, so that it could proceed with its analysis and inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on November 16, 2022, as stated in the certificate in the file.

On December 5, 2022, this Agency received a written response to the previous transfer submitted by the company QUICK LOPD SL in its capacity as Data Protection Delegate of CI POSTAL.

From the analysis of the response, the following statement is extracted:

- "At CIPOSTAL, we became aware of this incident on September 9, 2022, when the company HISPAPOST, to whom we provide postal services in Palma de Mallorca, informed us that the local police had contacted them to indicate that two bags of discarded mail with their logo had been collected."

THIRD: As a result of the transfer by the LOCAL POLICE of the report of the discovery of a large amount of abandoned correspondence in a vacant lot, as well as the discovery in an open area of numerous undelivered letters addressed to individuals, which had apparently been abandoned for several months, and in light of the media impact, the Director of the Spanish Agency for Data Protection, by Internal Note dated December 28, 2022, urged the General Subdirectorate for Data Inspection to initiate ex officio preliminary investigation actions aimed at verifying these facts and their authorship.

The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigation actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following points:

In relation to the security breaches reported to this Agency, it is noted:

From the breach reported by the controller BANCO SABADELL SA, the following is extracted:

- The complaint filed by HISPAPOST with the National Police on October 14, 2022, is attached.
- Description of the incident: "Banco de Sabadell, through communication made by its postal service provider (HISPAPOST) on ***DATE.4, became aware of the existence of several postal shipments to its clients in Palma de Mallorca found in different locations in the municipality discarded by personnel from the company responsible for distribution (Correo Inteligente Postal). Once the documentation was recovered, in various states of deterioration, by the FFCCEE, it was reviewed by Hispapost and they informed us that 252 shipments from Banco Sabadell to its clients are affected. These shipments, pending verification, could include account movements, information about balances, marketing, or any other type of personal and financial information. The facts have been reported."
- Number of affected individuals: 252.
- Date of detection: ***DATE.4.

From the breach reported by the controller PSA FINANCIAL SERVICES on ***DATE.5, the following is extracted:

- Description of the incident: "Our data processor, Servinform Sa, became aware through the postal company Hispapost, on 10/10, via a video published on social media, that the correspondence handled by another subcontractor was abandoned in the public way by their personnel in the city of Palma de Mallorca. Due to the type of letters sent, it is identified that approximately 90% corresponds to notifications related to debt recovery processes."
- Date of detection: ***DATE.1.

5/29

-

Volume of affected individuals: 44. The affected individuals will not be notified.

-

Attached is a security incident report dated November 14, 2022, from which the following statements are obtained:

□

“PSA Finance contracts the mailing services to SERVIFORM, S.A., which acts as the data processor. Servinform subcontracts the services to HISPAPOST, S.A., which in turn subcontracts the activity for the Palma de Mallorca region to CORREO INTELIGENTE POSTAL, S.L., with these two entities acting as sub-processors for PSA Finance.”

□

On October 18, HISPAPOST received information about the postal shipments that were recovered by the Police, confirming the existence of 5 letters corresponding to PSA FINANCE. The following day, ***DATE.2, SERVIFORM communicated the security incident to PSA FINANCE.

□

It has been estimated that 44 shipments have been potentially affected, and approximately 90% of these correspond to notifications related to debt recovery processes.

From the breaches reported by the responsible party ASNEF-EQUIFAX on ***DATE.5 and November 15, 2022, the following is extracted:

-

Description of the incident: “ASNEF-EQUIFAX, as the data controller of the ASNEF Bureau, communicates with consumers whose data has been included in said file. On 20/10/2022, HISPAPOST notified that an employee of the company responsible for the distribution of notifications (CORREO INTELIGENTE POSTAL, S.L. in Palma de Mallorca) left communications that were entrusted to be delivered abandoned in various locations in Palma de Mallorca. The provider initially indicates that the number of affected letters is 187; however, after the analyses conducted, the notifications total 47 notification letters of inclusion and 1 payment request. The actions taken by Equifax (regarding the processing for which it is responsible) have been: 1) to cancel the operations of the abandoned notifications that were recovered; 2) as a precautionary measure, all operations whose inclusion notifications may have been potentially compromised (from 1/1/22 to 20/10/22 in postal codes 07004, 07006, and 07008) have been canceled; and 3) the registration of these operations has been blocked for 45 days in the ASNEF file.”

-

Volume of affected individuals: 47.

-

Date of breach detection: ***DATE.1.

From the breaches reported by the responsible party INTRUM on October 24, 2022, and November 21, 2022, the following is extracted:

-

Description: “INTRUM SERVICING SPAIN has contracted with EQUIFAX a notification sending service, which in turn has HISPAPOST as a sub-processor. On 21/10 at 18:00, we were informed of an incident that has caused some of the notifications of Prior Requirements and inclusion in the bureau not to have been carried out. As measures taken so far by Hispapost, work with the responsible company has been halted.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/29

of the distribution of communications in P. de Mallorca and has presented the appropriate legal actions. The actions being carried out by Equifax, of which we will provide information as they progress, are as follows: i) determine the number of shipments from Intrum and the details of those sent to the affected postal codes in the indicated months ii) determine the recipients of the communications that have been included in the ASNEF file iii) Proceed to remove such data from the ASNEF file, if applicable, and the possible blocking of new entries in ASNEF iv) Determine the claims that the recipients of the involved communications may have made regarding the ASNEF file.”

-

Volume of affected individuals: 1.

-

Date of breach detection: ***DATE.5.

From the breaches reported by the responsible party VODAFONE on October 27, 2022, and November 25, 2022, the following is extracted:

-

Description: "Postal shipments (correspondence) from various clients have been found abandoned in different areas around the city of Palma de Mallorca. The postal distribution in this area was carried out by Correo Inteligente Postal, S.L., acting as a subcontractor for the processing of Hispapost S.A., an entity subcontracted by Equifax Ibérica, S.L., which in turn provides debt collection services to Vodafone as a data processor. The affected letters contain information about the recipient's unpaid debts to Vodafone, including the amount owed. Vodafone was notified by Equifax on October 24, 2022, via email. Vodafone has reviewed the incident and, after analyzing the provider, concluded that the number of clients potentially affected is 361."

-

Date of detection: October 24, 2022.

-

The reactive measures adopted by the processor EQUIFAX were:

☐ Proceed with the manual deregistration of clients included in the ASNEF file.

☐ All shipments from January to October have been analyzed.

From the breach reported by the responsible party PRA IBERIA SL on November 1, 2022, the following is extracted:

-

Description of the incident: "We received communication on ***DATE.5 from Equifax Ibérica, S.L.U. (Equifax) informing us of an incident with the correspondence related to the notification letters for inclusion in the ASNEF file. Upon reviewing the communication files to ASNEF, we confirmed that we have no record of registration, and this incident cannot affect our clients regarding communication to the ASNEF file. Subsequently, we asked Equifax if the service of sending correspondence to clients of PRA Iberia, S.L.U. (PRA) has also been affected. On October 28, 2022, we received official confirmation from Equifax of the abandonment of correspondence by an employee of a postal operator subcontracted by Equifax (Correo Inteligente Postal, S.L. -CI POSTAL-, through Hispapost, distribution in Palma de Mallorca), which affects the correspondence sent by PRA for the postal codes 07004, 07006, and 07008 from January 1, 2022, to October 10, 2022."

-

They state the detection date as: October 28, 2022.

-

They affirm the existence of 1023 potential affected individuals.

From the breaches reported by the responsible party CABOT FINANCIAL on November 3, 2022, and December 1, 2022, the following is extracted:

-

They state the detection date as: November 1, 2022.

-

Volume of affected individuals: 326.

-

They provide a report with the analysis and assessment of the breach, from which the following statements are extracted:

☐ "It has been a security breach that has compromised the confidentiality of the data as third parties could have accessed the information contained in the communication of inclusion in the ASNEF file, as well as the availability, to the extent that there would be an indeterminate number of lost communications that, as of the date of this Closing Report, have not yet been determined."

☐ "EQUIFAX confirms the number of 326 affected letters addressed to debtors."

From the breach reported by the responsible party EOS SPAIN SL on November 17 and December 7, 2022, the following is extracted:

-

Date of detection: November 15, 2022.

-

They provide a report of the incident from which the following statements are extracted:

☐ "Equifax has received from Hispapost 84 physical letters that have been directly recovered from the places where they were abandoned. The Police also have physical letters that are currently still held by the authorities as they constitute evidence in the investigation initiated by the competent Investigating Court for the processing of the corresponding criminal procedure. Equifax is unaware of the content of that correspondence in the possession of the Police."

☐ "The affected notifications include both the notifications of inclusion made by ASNEF-EQUIFAX to inform debtors of their inclusion in the ASNEF file, as well as notifications of prior payment requests from clients."

-

Potential volume of affected individuals: 1067.

Investigation directed at the data processor HISPAPOST SA:

On March 30, 2023, a request for information was made to HISPAPOST, marked by the following line of investigation:

- Investigate the incident register and the register of processing activities affected by the breach.
- Obtain information on the notification of the breach to this Agency and the communication to the affected individuals.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/29

- Investigate the notifications of the breach to the affected companies and those with which there was a service contract.
- Investigate the existence of service contracts with the affected companies.
- Investigate the service contract with the subcontractor CI POSTAL SL.
- Investigate the possible risk analysis and the accreditation of the preventive measures implemented.

On April 24, 2023, a response to the previous request was received, from its analysis the following relevant information is extracted:

- The documented record of the security breach is attached, from which the following statements are obtained:

☐ A total of 7924 postal shipments are claimed to have been recovered.

☐ It is not considered that the content of the letters was exposed in any case, so the affected data were "name and surname of the recipient and delivery postal address." They claim that the letters were found in remote abandoned places, so exposure to a large number of people is ruled out.

☐ They assert that the letters are ordinary shipments (not certified), so significant consequences for the interested parties resulting from the non-receipt of the letter are ruled out, and that each of their clients (who mostly acted as data controllers) was informed to assess this impact. It was considered that "no damage could occur to the rights and freedoms of the affected."

☐ They provide the following chronology of events (which only refers to the letters found in October, with no reference in this chronology to the shipment of letters located by the Local Police in September 2022):

☐ On October 10 at 17:20, they receive information about a video published on the internet. The correspondence is recovered by HISPAPOST personnel.

☐ On ***DATE.3 new shipments are located following an alert from a citizen.

☐ On October 14, the incident is reported to the DPO and a complaint is filed with the National Police.

☐ On October 17, 2022, the found correspondence arrives at HISPAPOST facilities in Madrid for analysis and quantification of affected clients. On this same October 17, 2022, new findings are discovered by the police and media.

☐ On October 19, detailed information about the shipments recovered by the police is received; the

letters are returned to the clients or discarded based on their instructions.

- ☐ From October 14 to 21, the incident is notified to the affected clients.
- ☐ It is stated that "the shipments made to the city of Palma de Mallorca do not allow for the traceability control that HISPAPOST applies to its ordinary shipments, as there is a logistical difficulty due to transportation."
- ☐ They provide a list of the reactive measures adopted by the company:
- ☐ Closure of distribution in Palma de Mallorca.
- ☐ Increase inspections in the distribution network.
- ☐ Reminder to staff about responsibilities in deliveries.
- ☐ Avoid working in postal codes where there are no shipments with traceability to be able to evaluate the status of these daily (considering having a minimum number of shipments with traceability).
- ☐ Deployment of internal panelists to monitor correspondence.
- ☐ Reinforcement in training and awareness of employees.

- The complaint filed by HISPAPOST on October 14, 2022, is attached; from the analysis of this complaint, the following relevant statements are extracted:

- ☐ It is stated: "On October 10, 2022, HISPAPOST receives a message from CI POSTAL in which they send a video taken from Telegram showing a man commenting and filming thousands of letters scattered in a junkyard sent from HISPAPOST, which contain personal data of clients (Naturgy and Endesa among others)... that these letters were collected by the distributor in Mallorca on October 11, 2022, and were sent back on ***DATE.3 to the reporting company."
- ☐ "On ***DATE.3 a message is received from CaixaBank informing that one B.B.B. has found approximately 4000 letters addressed to CaixaBank in perfect condition, which were thrown by an unknown individual from a vehicle at 19:00 on October 10, 2022."

- The Record of Processing Activities (RAT) of HISPAPOST as a data processor, updated to December 14, 2022, is provided. From the analysis of this RAT by the present inspector, it is concluded that HISPAPOST was carrying out processing on behalf of the following data controllers:

- ☐ For the data controller AMPLIFÓN IBÉRICA SAU:
- ☐ Description of processing: Postal distribution service.
- ☐ Authorization for subcontracting exists: YES.
- ☐ "ISO 27001 security measures and basic, medium, and high-level security measures RD 1720/2007."
- ☐ Regarding breach notifications: obligation to notify within 24 hours.
- ☐ For the data controller BANCO SABADELL SA:
- ☐ Description of processing: Provision of postal services.
- ☐ Authorization for subcontracting exists: YES.
- ☐ "ISO 27001 security measures and basic, medium, and high-level security measures RD 1720/2007."
- ☐ Regarding breach notifications: obligation to notify within 24 hours.
- ☐ For the client data controller BBVA SA:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/29

☐

Description of processing: Mail services, Telegrams and Buofaxes, Mailbag, National and International Messaging.

☐

There is authorization for subcontracting: YES.

☐

"ISO 27001 security measures and basic, medium, and high-level security measures RD 1720/2007."

☐

Regarding breach notification: obligation to notify immediately.

☐

For the data controller CAIXABANK FACILITIES MANAGEMENT SA:

☐

Description of processing: Collection and home delivery of correspondence for CaixaBank.

☐

There is authorization for subcontracting: YES.

☐

"ISO 27001 security measures and basic, medium, and high-level security measures RD 1720/2007."

☐

Regarding breach notification: obligation to notify immediately.

☐

For the data controller EQUIFAX IBERICA SL (B80855398):

☐

It is stated that this client acts as the Data Controller of the personal data processed.

☐

Description of processing: Postal services.

☐

There is authorization for subcontracting: YES.

☐

"ISO 27001 security measures and basic, medium, and high-level security measures RD 1720/2007."

☐

Regarding breach notification: obligation to notify within 24 hours.

☐

For the data controller ENDESA SA:

☐

Description of processing: postal services.

☐

There is authorization for subcontracting: YES.

☐

"ISO 27001 security measures and basic, medium, and high-level security measures RD 1720/2007."

☐

Regarding breach notification: obligation to notify within 48 hours.

☐

For the data controller NATURGY CLIENTES SA:

☐

Description of processing: postal services.

☐

There is authorization for subcontracting: YES.

☐

"ISO 27001 security measures and basic, medium, and high-level security measures RD 1720/2007."

☐

Regarding breach notification: obligation to notify within 24 hours.

☐

For the client SERVIFORM SA:

☐

It is stated that this client acts as the Data Processor of the personal data.

☐

Description of processing: postal distribution for PSA FINANCIAL SERVICES SPAIN, E.F.C., S.A (which acts as the Data Controller).

☐

There is authorization for subcontracting: YES.

☐

"ISO 27001 security measures and basic, medium, and high-level security measures RD 1720/2007."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/29

☐

Regarding breach notification: obligation to notify within 24 hours.

☐

For the data controller AYUNTAMIENTO DE MADRID (General Directorate of Contracting and Services):

☐

The client is the Data Controller.

☐

Description of processing: Postal distribution for the City Council of Madrid and its Autonomous Organizations.

☐

Data: identifying data (name, surname, and postal address), corresponding to the processing activity "Executive Collection."

☐

There is authorization for subcontracting: YES.

☐

Retention period 3 months.

☐

"ISO 27001 security measures and basic, medium, and high-level security measures RD 1720/2007."

☐

Regarding breach notification: obligation to notify within 48 hours.

☐

For the data controller GRUPO MEDINA CUADROS (MC ABOGADOS SL + TELEFAX):

☐

The client is the Data Controller.

☐

Description of processing: postal services.

☐

There is authorization for subcontracting: YES.

☐

"ISO 27001 security measures and basic, medium, and high-level security measures RD 1720/2007."

☐

Regarding breach notification: obligation to notify within 24 hours.

☐

For the data controller AYUNTAMIENTO DE SEVILLA (Seville Tax Agency):

☐

Description of processing: postal services.

☐

There is authorization for subcontracting: YES.

☐

"ISO 27001 security measures and basic, medium, and high-level security measures RD 1720/2007."

☐

Regarding breach notification: within 24 hours.

☐

For the data controller ASOCIACIÓN ESPAÑOLA CONTRA EL CÁNCER:

☐

Description of processing: postal services.

☐

There is authorization for subcontracting: YES.

☐

Retention period 3 months.

☐

“ISO 27001 security measures and basic, medium, and high-level security measures RD 1720/2007.”

☐

Regarding breach notification: within 24 hours.

-

In relation to breach notification, it states: “Hisapost, as the data processor of the data involved in the incident, informed its clients (Data Controllers) about the incident that occurred so that they could assess the incident and determine if it could be considered a security breach, and if so, make the appropriate communication of the security breach to the Data Protection Agency.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/29

- Attached is a document with a report drafted by the DPO of HISPAPOST, the company Ascendia Reingeniería Y Consulting, S.L., signed on April 21, 2023, containing the assessment of the breach. From the analysis of this report, the following conclusions are drawn:

- “HISPAPOST, as Data Processor and in accordance with Article 33 of the GDPR, is not obliged to notify the security incident, as it is not within its responsibility and because the rights and freedoms of the data subjects have not been affected.”

- “It would not be necessary to communicate the security breach to the affected parties, as it is not considered that there may be a high or very high risk to the rights and freedoms of the affected subjects.”

- Regarding the notification of the breach to all affected companies acting as data controllers of the affected personal data (clients of HISPAPOST), the following is documented:

☐ Notification made to the controller ASOCIACIÓN ESPAÑOLA CONTRA EL CÁNCER (AECC), with a screenshot of the email sent on ***DATE.1.

☐ Notification made to the AGENCIA TRIBUTARIA DE SEVILLA, with a screenshot of the email sent on ***DATE.1.

☐ Notification made to ASISA, with a screenshot of the email sent on ***DATE.2. This notification is first made to the client SERVIFORM on ***DATE.2; this client acts as the data processor for the controller ASISA, and it is documented that on the same day ***DATE.2, the notification with the incident report was sent to this controller.

☐ Notification made to BBVA, with a screenshot of the email sent on ***DATE.1.

☐ Notification made to CAIXABANK, with a screenshot of the email sent on ***DATE.2.

☐ Notification made to ENDESA, with a screenshot of the emails sent on ***DATE.3 and ***DATE.1.

☐ Notification made to EQUIFAX, with a screenshot of the email sent on ***DATE.1.

☐ Notification made to GAES (formerly known as AMPLIFON IBÉRICA SAU), with a screenshot of the email sent on ***DATE.4.

☐ Notification made to GRUPO MASMOVIL, with a screenshot of the email sent on ***DATE.1.

☐ Notification made to NATURGY, with a screenshot of the email sent on ***DATE.3, including a general statement about the incident.

☐ Notification made to GRUPO ORANGE, with a screenshot of the email sent on ***DATE.1.

☐ Notification made to PSA FINANCIAL, with a screenshot of the email sent from the address ***EMAIL.1 on ***DATE.1. According to the RAT, HISPAPOST acts as the data processor for SERVIFORM, which simultaneously acts as the data processor for the postal distribution of the controller PSA FINANCIAL SERVICES.

C/ Jorge Juan, 6

13/29

- ☐ Notification made to BANCO SABADELL, with a screenshot of the email sent on ***DATE.4.
- ☐ Notification made to MC ABOGADOS Y TELEFAX, with a screenshot of the email sent on ***DATE.5.
- ☐ Notification made to TR3A, with a screenshot of the email sent on ***DATE.1, the email is sent from the address ***EMAIL.2 to the recipient ***EMAIL.3.
- A copy of the data processing agreement between HISPAPOST and CI POSTAL is attached, from which the following relevant information is extracted:
 - ☐ The contract was signed on January 10, 2022, and it details the types of data affected by the agreement, the categories of data subjects, the processing operations, the international transfers, and the data of both DPOs.
 - ☐ It is stated that HISPAPOST has the status of data processor while CI POSTAL is a sub-processor, with THE CLIENT OF HISPAPOST acting as the data controller of the data affected by the agreement.
 - ☐ The obligations of the provider CI POSTAL as a sub-processor are detailed, among which the following stand out:
 - ☐ Ensure that the individuals authorized to process personal data commit expressly and in writing to respect confidentiality and comply with the corresponding security measures, of which they must be duly informed.
 - ☐ Ensure the necessary training in personal data protection for the authorized individuals.
 - ☐ According to Article 32 of the GDPR, CI POSTAL commits to adopt the necessary measures to prevent alteration, loss, processing, or unauthorized access to the personal data of HISPAPOST's clients, taking into account the state of technology, the nature of the data, and the risks involved, whether arising from human action or from physical or natural means. CI POSTAL states that it has a Privacy Manual that determines the technical and organizational measures to be implemented.
 - ☐ CI POSTAL will notify HISPAPOST without undue delay and as quickly as possible and in any case before 24 hours, via email ***EMAIL.4, of any security breaches unless it is unlikely to constitute a risk to the rights and freedoms of natural persons.
 - ☐ It is the responsibility of HISPAPOST or its client (data controller) to notify the breaches to the AEPD and to the affected individuals.
 - ☐ In accordance with the risk assessment carried out by the client of HISPAPOST, and as established in Article 28 of the GDPR, CI POSTAL must implement at least the security measures corresponding to the medium level in accordance with the provisions of the Regulation developing the LOPD (RLOPD) RD 1720/2007, unless other measures are specified in its replacement.

C/ Jorge Juan, 6

14/29

- Copies of the data processing agreements that existed between HISPAPOST and each of its clients to whom it provided postal distribution services and that were affected by the breach are submitted, as follows:
 - ☐ A copy of the processing agreement with the data controller ASISA, signed on January 1, 2022. This agreement details the obligations of the processor and controller, the authorized subcontracting, notification of data security breaches within a maximum period of 24 hours, and rights. It includes an annex with a template of the types of data affected by the contract; however, this annex is not filled out, and the details of the types of data affected by the agreement are not specified.
 - ☐ A copy of the processing agreement with the AYUNTAMIENTO DE MADRID, signed on January 26, 2021. This contract specifies the authorization to subcontract the service with CI POSTAL.
 - ☐ A copy of the processing agreement with the data controller BBVA, signed on April 13, 2021.

- ☐ A copy of the processing agreement with the data controller CAIXABANK, signed on July 19, 2019, which regulates the obligation to notify incidents with the following clause: "the processor guarantees that it will establish maximum diligence measures to detect breaches and that it will communicate to CAIXABANK without undue delay and as soon as possible."
- ☐ A copy of the processing agreement with EQUIFAX IBERICA SL, signed on April 1, 2019. This contract is signed between HISPAPOST and EQUIFAX-IBÉRICA SL with NIF B80855398. Among its clauses, the obligations that the data processor (HISPAPOST) commits to regarding the confidentiality of the processed data are detailed:
 - ☐ Authorized persons in the processing of personal data will be required to commit to confidentiality and assume responsibilities in case of breach.
 - ☐ Ensure that authorized persons for processing personal data commit, expressly and in writing, to respect confidentiality and comply with security measures, of which they must be adequately informed.
 - ☐ Ensure the necessary training for authorized persons.
 - ☐ Obligation to notify breaches within 24 hours via email; this notification will not be necessary when it is unlikely that the breach constitutes a risk to the rights and freedoms of the affected individuals, corresponding to HISPAPOST to communicate data security breaches to the Spanish Agency for Data Protection and to EQUIFAX-IBERICA to communicate the breach to the affected individuals, if applicable.
- ☐ A copy of the processing agreement with AMPLIFON IBERICA SAU A59198770 (formerly known as GAES), signed on March 30, 2021, is submitted. Among its clauses, HISPAPOST is authorized to subcontract services with all members of its distribution network where it does not have its own coverage, and the obligation to notify breaches within 24 hours via email is specified.
- ☐ A copy of the processing agreement with SERVIFORM, signed on January 15, 2019. From the analysis of this contract, the following statements are extracted:
 - ☐ Notification of security breaches must be made within a maximum period of 24 hours from their detection.
 - ☐ The contract authorizes the subcontracting of CI POSTAL.
- ☐ A copy of the processing agreement between PSA FINANCIAL SERVICES and SERVIFORM SA is also submitted, authorizing the possibility of subcontracting to HISPAPOST and specifying the obligation to notify breaches within 24 hours.
- ☐ A copy of the processing agreement with BANCO SABADELL, signed on February 24, 2022, is submitted. Its content highlights the obligation to notify security breaches within a maximum period of 24 hours from detection.
- ☐ A copy of the processing agreement with ENDESA, signed on February 1, 2022, is submitted, highlighting the obligation to notify breaches within a maximum period of 48 hours.
- ☐ A copy of the processing agreement with NATURGY CLIENTES SA, signed on March 31, 2022, is submitted, highlighting the obligation of the processor to notify breaches within a maximum period of 24 hours. The subcontracting of CI POSTAL is expressly authorized in the contract.
- In response to the request, a document with a report of the Data Protection Impact Assessment (DPIA) regarding the postal distribution processing activity is also submitted. From the analysis of this document, the following considerations are extracted:
 - ☐ The initial date of completion is October 28, 2021, and it was subsequently modified after the breach on ***DATE.1.
 - ☐ The participation of the DPO is affirmed.
 - ☐ A description of the processing and the existing flow of information is provided.
 - ☐ The following threats and risks are analyzed, among others:
 - ☐ Organizational deficiencies in access control management.
 - ☐ Breaches of the confidentiality of personal data by employees of the organization and external operators.
 - ☐ Lack of training for staff.
 - ☐ Poor management of subcontracting.

28001 – Madrid
sedeagpd.gob.es
16/29

☐ The 2022 update was carried out following the security breach and consisted of raising the quantitative value assigned to the probability for the risk factor "Violations of the confidentiality of personal data by employees of the organization," concluding with new mitigation measures, including:

☐ Avoid working with postal codes where there are not enough traceable shipments by establishing a blocking value for this.

☐ Increase the frequency of inspections of the delivery network.

☐ Send reminders to all staff.

☐ Implement internal panelists to monitor correspondence.

- A document is provided containing the list of reactive measures implemented by HISPAPOST after the security breach, highlighting the following:

☐ Internal control and monitoring of the traceability of deliveries and shipments.

☐ Increase the frequency of inspections of the entire delivery network.

☐ Launch a new reminder to all staff regarding the legal repercussions of retaining, storing, concealing, opening, or destroying any postal shipment.

☐ Avoid working in postal codes where there are not enough traceable shipments to evaluate the results daily.

☐ Review current services with characteristics compatible with the traceability defect for risk assessment of the service and establish actions.

☐ Implement internal panelists in as many populations as possible to monitor the arrival of correspondence.

☐ Reinforce training and awareness of all HISPAPOST staff regarding Data Protection regulations and compliance with the duty of confidentiality.

- In response to indicate possible similar incidents that have occurred in the organization, they state that another incident occurred related to the intentional abandonment of ordinary letters by a worker of the company responsible for postal distribution in the city of León, specifically the company SOLIDARIDAD Y TRABAJO VIRGEN DEL CAMINO, SL (SOLTRA), a special employment center.

Regarding this incident, they state:

☐ That SOLTRA informed HISPAPOST on October 25, 2022.

☐ That on October 26, 2022, the worker acknowledged the facts and delivered 2,887 letters that he had at home. There was no certainty about the number of letters or affected clients, as that information was in the hands of the Police and the Courts. It was in the first week of April that we received confirmation of affected clients and the total number of recovered letters, 8,881 closed letters (ordinary postal mail).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/29

☐

That HISPAPOST proceeded to inform the affected clients.

On June 20, 2023, a second request for information was decided to be made to HISPAPOST marked by the following line of investigation:

- It is requested to certify whether there were notifications of the security breach to the responsible parties (clients) affected by the abandonments located by the Local Police in September 2022, of which they were aware on the same September 13, 2022, according to the police report.

- To clarify some of the measures implemented to ensure the traceability of the shipments.

- To certify the reactive measure adopted "Awareness actions for the entire distribution network and Collection of evidence of the implementation of awareness actions among the network of collaborators," specifically, accreditation of the results obtained for the distributor CI POSTAL is requested.

On June 29, 2023, a response to the previous request was received, and from its analysis, the following statements are extracted:

- "On September 13, personnel from CI Postal went to the police station and identified the letters (1404 letters from different clients), and on September 22, CI Postal collected the letters from the Local Police station in Palma, none of the letters had been opened or manipulated."

- "After evaluating the factors involved in the incident (during the last week of September and the first of October, as information was obtained): the limited number of affected letters, their good condition without being opened or manipulated, the possibility of resuming distribution, the location of the finding in a remote and inaccessible place (which reduces the probability of them being accessible), the type of letters which were ordinary mail (which rules out contents that could generate significant consequences for the interested parties), the intentional cause by CI Postal employees; it was considered unlikely that damages could occur to the rights and freedoms of the individuals whose data were exposed, as no high or very high risk for the rights and freedoms of the affected was perceived, and at that moment, it was not deemed necessary to communicate to the affected clients.

Communication to those clients was made days later regarding the new findings that occurred in October (detected on October 11, 2022)."

- "The sensitive postal codes or those with traceability defects are all those of Palma de Mallorca (the only city in the Balearic Islands that Hispapost distributed), with the sub-processor being the company CI Postal, and due to the impossibility of controlling the service, it was decided not to resume the service from the occurrence of the incident."

- "Ordinary shipments do not allow for any type of direct traceability either by Hispapost or by any postal operator. The processing of this type of shipment is done manually (on paper) and the only data that Hispapost manages are the volumes of clients and letters. As for the traceability control that Hispapost applies for this type of shipment, it is done indirectly through the following means:

☐ Indirect control through certified shipments

☐ Control of complaints

☐ Periodic inspections."

- Evidence of some periodic inspections carried out in distribution centers is accredited, and the manual used to carry them out is also provided.

- In relation to our request for them to certify the awareness actions they had obtained from the sub-processor CI POSTAL, they provide:

☐ Accreditation of an informative communication directed to the workers of CI POSTAL on November 19, 2021, regarding the consequences of non-compliance with regulations, the ethical code, and the COMPLIANCE program.

☐ They accredit a training session in December 2021 with the following content, without specifying the duration of the training: Ethical Code, Confidentiality Agreement, Criminal Risks at work, Disciplinary Regime, and Whistleblower Channel.

FIFTH: According to the report collected from the AXESOR tool, the entity HISPAPOST, S.A. is a large company established in 2018, with a turnover of €30,996,274 in 2022.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Data Protection Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Data Protection Agency will be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

C/ Jorge Juan, 6

www.aepd.es

II

Preliminary Issues

Article 4 of the GDPR establishes that:

For the purposes of this Regulation, the following shall be understood as:

1) “personal data”: any information relating to an identified or identifiable natural person (“the data subject”); an identifiable natural person is one whose identity can be determined, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic, cultural, or social identity of that person;

In point 2 of the same article, the concept of “processing” of personal data is defined.

2) “processing”: any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or any other form of making available, alignment, combination, restriction, erasure, or destruction;

In the present case and in accordance with the report from the LOCAL POLICE, dated September 22, 2022, it is noted that abandoned correspondence containing personal data (name and surname, and postal address) was found in a vacant lot, totaling 1,404 letters belonging to various companies, which bore the logo of the company HISPAPOST. For this reason, this entity was contacted by the LOCAL POLICE agents, who recognized that the found correspondence should have been delivered by employees of CI POSTAL, without understanding the reason why such delivery was not carried out and the correspondence was abandoned.

Subsequently, a new complaint was received from the Government Delegation in the Balearic Islands, which forwarded a letter sent by the Superior Police Headquarters of the Balearic Islands regarding the location of a total of 5,354 letters abandoned in two different locations in La Palma, for which the company HISPAPOST was responsible, managing the delivery through its distributor in La Palma, CI POSTAL SL.

In Article 4 of the GDPR, points 7 and 8 specify what is to be understood as the data controller and the data processor. Thus, we have:

“7) ‘data controller’ or ‘controller’ means the natural or legal person, public authority, agency, or other body which, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of processing, the controller or the specific criteria for its designation may be provided for by the law of the Union or of the Member States;

8) ‘data processor’ or ‘processor’ means the natural or legal person, public authority, agency, or other body which processes personal data on behalf of the controller...”

In summary, the data controller is the natural or legal person or public authority that decides on the processing of personal data, determining the purposes and means of such processing.

By virtue of the principle of proactive responsibility, the data controller must implement technical and organizational measures to comply with and be able to demonstrate compliance, taking into account the risks involved in the processing of personal data.

For its part, the data processor is the natural or legal person, public authority, agency, or other body that provides a service to the controller that involves the processing of personal data on behalf of the controller.

In this sense, the controller is the one who decides the “why” and the “how” regarding personal data, and the processor is the one who carries out the processing on behalf of the controller.

In the present case, HISPAPOST is the data processor of personal data belonging to various companies (Amplifón Ibérica S.A.U., Banco Sabadell, S.A., BBVA, S.A., Caixabank Facilities Management, S.A., Equifax Ibérica, S.L., Endesa, S.A., Naturgy Clientes, S.A., Servinform, S.A., City Council of Madrid, Grupo Medina Cuadros, City Council of Seville, Spanish Association Against

Cancer, Asisa, PSA Financial Services) with which it has signed the corresponding processing agreement to provide postal distribution services.

III

Article 28 of the GDPR

The figure of the data processor in the GDPR is defined in its Article 28, which establishes the requirements that must be met regarding data protection:

1. When processing is to be carried out on behalf of a data controller, the controller shall choose only a processor that provides sufficient guarantees to implement appropriate technical and organizational measures, so that the processing will be in compliance with the requirements of this Regulation and will ensure the protection of the rights of the data subject.

2. The processor shall not engage another processor without prior written authorization, specific or general, from the controller. In the latter case, the processor shall inform the controller of any intended changes concerning the addition or replacement of other processors, thereby giving the controller the opportunity to object to such changes.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/29

3. The processing by the processor shall be governed by a contract or other legal act in accordance with Union law or the law of the Member States, which binds the processor to the controller and establishes the subject matter, duration, nature, and purpose of the processing, the type of personal data and categories of data subjects, and the obligations and rights of the controller. Such contract or legal act shall stipulate, in particular, that the processor:

a) shall process personal data only on documented instructions from the controller, including with regard to the transfers of personal data to a third country or an international organization, unless required to do so by Union law or the law of the Member States applicable to the processor; in such a case, the processor shall inform the controller of that legal requirement prior to the processing, unless that law prohibits such information on important grounds of public interest;

b) shall ensure that persons authorized to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality;

c) shall take all necessary measures in accordance with Article 32;

d) shall respect the conditions laid down in paragraphs 2 and 4 for engaging another processor;

e) shall assist the controller, taking into account the nature of the processing, by means of appropriate technical and organizational measures, insofar as this is possible, so that the controller can comply with its obligation to respond to requests for the exercise of the rights of data subjects laid down in Chapter III;

f) shall assist the controller in ensuring compliance with the obligations laid down in Articles 32 to 36, taking into account the nature of the processing and the information available to the processor; (...). These specific obligations may be monitored by data protection authorities, without prejudice to the oversight that may be carried out regarding compliance with the GDPR or the LOPDGDD by the controller or the processor.

Regarding the notification of the breach, it is recorded in the file that: "Hisapost, as the processor of the data involved in the incident, informed its clients (Controllers of Processing) about the incident that occurred so that they could assess the incident and determine if it could be considered a security breach, and if applicable, make the appropriate notification of the security breach to the Data Protection Agency."

It is evident the obligation that HISPAPOST has to notify the controllers of processing of any security incident suffered, and this is reflected in the Record of Processing Activities (RAT) of HISPAPOST as the processor, updated as of December 14, 2022:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

22/29

- For the controller AMPLIFÓN IBÉRICA SAU: there is an obligation to notify within 24 hours.
- For the controller BANCO SABADELL SA: there is an obligation to notify within 24 hours.
- For the client controller BBVA SA: there is an obligation to notify immediately.
- For the client controller CAIXABANK FACILITIES MANAGEMENT SA: there is an obligation to notify immediately.
- For the controller EQUIFAX IBERICA SL (B80855398): there is an obligation to notify within 24 hours.
- For the client controller ENDESA SA: there is an obligation to notify within 48 hours.
- For the client controller NATURGY CLIENTES SA: there is an obligation to notify within 24 hours.
- For the client SERVIFORM SA: there is an obligation to notify within 24 hours.
- For the client controller AYUNTAMIENTO DE MADRID (Dirección General Contratación y Servicios): there is an obligation to notify within 48 hours.
- For the client controller GRUPO MEDINA CUADROS (MC ABOGADOS SL + TELEFAX): there is an obligation to notify within 24 hours.
- For the client controller AYUNTAMIENTO DE SEVILLA (Agencia Tributaria de Sevilla): there is an obligation to notify within 24 hours.
- For the client controller ASOCIACIÓN ESPAÑOLA CONTRA EL CÁNCER: there is an obligation to notify within 24 hours.

This obligation is also reflected in the following contracts signed by HISPAPOST:

- With ASISA, on January 1, 2022, where the obligation to notify data security breaches within a maximum period of 24 hours is indicated.
- With CAIXABANK, on July 19, 2019, among whose content it is indicated that the processor will communicate data security breaches “without undue delay and as soon as possible.”
- With EQUIFAX-IBÉRICA SL, on April 1, 2019, among whose clauses is the obligation to notify data security breaches within 24 hours via email, this notification not being necessary when it is unlikely that the breach constitutes a risk to the rights and freedoms of the affected individuals.
- With AMPLIFON IBERICA SAU on March 30, 2021, among whose clauses specifies the obligation to notify data security breaches within 24 hours via email.
- With SERVIFORM, on January 15, 2019, which indicates that the notification of data security breaches must be made within a maximum period of 24 hours from their detection.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/29

- With PSA FINANCIAL SERVICES and SERVIFORM SA, specifying the obligation to notify data security breaches within 24 hours.
- With BANCO SABADELL, on February 24, 2022, which includes the obligation to notify data security breaches within a maximum period of 24 hours from detection.
- With ENDESA, on February 1, 2022, which includes the obligation to notify data security breaches within a maximum period of 48 hours.
- With NATURGY CLIENTES SA, on March 31, 2022, which includes the obligation of the processor to notify breaches within a maximum period of 24 hours.

In relation to the notification of the breach to all affected companies acting as data controllers of the affected personal data (clients of HISPAPOST), the following are documented:

- Notification made to the responsible party ASOCIACIÓN ESPAÑOLA CONTRA EL CÁNCER (AECC), providing a screenshot of the email sent on ***DATE.1.
- Notification made to the AGENCIA TRIBUTARIA DE SEVILLA, providing a screenshot of the email sent on ***DATE.1.
- Notification made to ASISA, providing a screenshot of the email sent on ***DATE.2. This notification

was first made to the client SERVIFORM on ***DATE.2; this client acts as the data processor for the responsible party ASISA, and it is documented that on the same day ***DATE.2, the notification with the incident report was sent to this responsible party.

- Notification made to BBVA, providing a screenshot of the email sent on ***DATE.1.
- Notification made to CAIXABANK, providing a screenshot of the email sent on ***DATE.2.
- Notification made to ENDESA, providing a screenshot of the emails sent on ***DATE.3 and ***DATE.1.
- Notification made to EQUIFAX, providing a screenshot of the email sent on ***DATE.1.
- Notification made to GAES (formerly known as AMPLIFON IBÉRICA SAU), providing a screenshot of the email sent on ***DATE.4.
- Notification made to GRUPO MASMOVIL, providing a screenshot of the email sent on ***DATE.1.
- Notification made to NATURGY, providing a screenshot of the email sent on ***DATE.3 with a general statement regarding the incident.
- Notification made to GRUPO ORANGE, providing a screenshot of the email sent on ***DATE.1.
- Notification made to PSA FINANCIAL, providing a screenshot of the email sent from the address ***EMAIL.1 on ***DATE.1.

According to the RAT, HISPAPOST acts as the data processor for SERVIFORM, and at the same time acts as the data processor for the postal distribution of the responsible party PSA FINANCIAL SERVICES.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

24/29

- Notification made to BANCO SABADELL, providing a screenshot of the email sent on ***DATE.4.
- Notification made to MC ABOGADOS Y TELEFAX, providing a screenshot of the email sent on ***DATE.5.
- Notification made to TR3A, providing a screenshot of the email sent on ***DATE.1, the email was sent from the address ***EMAIL.2 to the recipient ***EMAIL.3.

Since it was in September 2022 when the Local Police contacted HISPAPOST SA to inform them of the discovery of abandoned correspondence in a lot, and that the notifications made to its clients took place between October 13 and October 21, 2023, HISPAPOST has not complied with the provisions established in the corresponding data processor contracts signed with such clients, who are ultimately the data controllers of the affected personal data.

In accordance with the evidence available in this initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that the known facts could constitute an infringement, attributable to HISPAPOST for violation of Article 28.3 of the GDPR.

IV

Classification of the infringement of Article 28.3 of the GDPR

If confirmed, the aforementioned infringement of Article 28.3 of the GDPR could imply the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements," establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 73 "Infringements considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a two-year statute of limitations: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/29

q) The failure of the data processor to notify the data controller of security breaches of which it became aware (...)

V

Sanction for the infringement of Article 28.3 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, it is necessary to assess the sanction to be imposed in accordance with the following criteria established by Article 83.3 of the GDPR and Article 76.2 of the LOPDGDD:

As an aggravating factor:

- b) The connection of the infringer's activity with the processing of personal data (Article 76.2.b) of the LOPDGDD).

HISPAPOST is engaged in the provision of all kinds of postal services, including the collection, admission, classification, processing, routing, transportation, distribution, and delivery of all kinds of postal items, advertising, and parcels, as well as meter reading.

Consequently, for the purpose of complying with the legally established requirements, the exercise of such activity necessarily implies knowledge and application of the current regulations regarding the protection of personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 28.3 of the GDPR, allows for an initial sanction of €60,000 (SIXTY THOUSAND EUROS).

VI

Adoption of measures

If the infringement is confirmed, it may be agreed to impose on the controller the adoption of appropriate measures to adjust its actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to bring the processing operations into compliance with the provisions of this Regulation, where appropriate, in a specified manner and within a specified time frame...". The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided for in Article 83.2 of the GDPR.

It is noted that failure to comply with a possible order to adopt measures imposed by this body in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in Articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning procedures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/29

Therefore, in light of the above, by the Director of the Spanish Agency for Data Protection,

IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against HISPAPOST, S.A., with NIF A88201546, for the alleged infringement:

- Of Article 28.3 of the GDPR, classified in Article 83.4.a) of the GDPR.

SECOND: TO APPOINT C.C.C. as instructor and D.D.D. as secretary, indicating that they may be challenged, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the sanctioning file, for evidentiary purposes, the complaints filed and their documentation, as well as the documents obtained and generated by the General Subdirectorate of Data Inspection in the actions prior to the initiation of this sanctioning procedure.

FOURTH: THAT for the purposes provided for in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond, without prejudice to what results from the instruction, would be:

- For the alleged infringement of Article 28.3 of the GDPR, classified in Article 83.4.a) of that regulation, an administrative fine of €60,000.00.

FIFTH: TO NOTIFY this agreement to HISPAPOST, S.A., with NIF A88201546, granting it a hearing period of ten business days to submit any allegations and present any evidence it deems appropriate. In its written allegations, it must provide its NIF and the file number indicated in the heading of this document.

If no allegations are made regarding this initiation agreement within the stipulated period, it may be considered a proposal for resolution, as established in Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

In accordance with the provisions of Article 85 of the LPACAP, it may acknowledge its responsibility within the period granted for the submission of allegations to this initiation agreement; this will entail a 20% reduction of the sanction that may be imposed in this procedure. With the application of this reduction, the sanction would be set at €48,000.00, resolving the procedure with the imposition of this sanction.

Similarly, it may, at any time prior to the resolution of this procedure, voluntarily pay the proposed sanction, which will imply a 20% reduction of its amount. With the application of this reduction, the sanction would be set at €48,000.00, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/29

The reduction for the voluntary payment of the sanction is cumulative with the one that corresponds to be applied for the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted to submit allegations regarding the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions are applicable, the amount of the sanction will be established at 36,000.00 euros.

In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the sanction.

In the event that you choose to proceed with the voluntary payment of either of the amounts indicated above (48,000.00 euros or 36,000.00 euros), you must make it effective by depositing it into account no. IBAN: ES00 0000 0000 0000 0000 0000 (BIC/SWIFT Code: XXXXXXXXXXXX) opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which you are adhering.

You must also send the proof of payment to the General Subdirectorate of Inspection to continue with the procedure in accordance with the amount deposited.

The procedure will have a maximum duration of twelve months from the date of the initiation agreement. If this period elapses without a resolution being issued and notified, it will become void, and consequently, the file of actions will occur; in accordance with the provisions of Article 64 of the LOPDGDD.

Finally, it is noted that according to the provisions of Article 112.1 of the LPACAP, no administrative appeal can be made against this act.

935-30102023

Mar España Martí

Director of the Spanish Agency for Data Protection

>>

SECOND: On January 16, 2024, the respondent has proceeded to pay the sanction in the amount of 36,000 euros making use of the two reductions provided for in the previously transcribed Initiation Agreement, which implies the acknowledgment of responsibility.

THIRD: The payment made, within the period granted to submit allegations regarding the opening of the procedure, entails the renunciation of any action or administrative appeal against the sanction and the acknowledgment of responsibility concerning the facts referred to in the Initiation Agreement.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/29

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in sanctioning procedures" provides the following:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely of a pecuniary nature or when it is possible to impose a pecuniary sanction and another of a non-pecuniary nature but the impropriety of the latter has been justified, the voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent body to resolve the procedure will apply reductions of at least 20% on the amount of the proposed sanction, which will be cumulative. The aforementioned reductions must be determined in the notification of initiation of the procedure, and their effectiveness will be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the sanction. The percentage of reduction provided for in this section may be increased by regulation."

In accordance with the above,

the Director of the Spanish Agency for Data Protection RESOLVES:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/29

FIRST: DECLARE the termination of the procedure EXP202313042, in accordance with the provisions of Article 85 of the LPACAP.

SECOND: NOTIFY this resolution to HISPAPOST, S.A.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative process as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within a period of two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

936-040822

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es